ARACHNE SENTINEL

Güvenlik Değerlendirme Brifingi — Kırmızı Takım Görev Tanımı

1. Proje Hakkında

Arachne Sentinel; honeypot (aldatma) teknolojisi temelli bir erken uyarı, saldırı tespiti, otonom müdahale ve ölçülebilir SOC platformudur. Gerçek dünyadaki savunma ürünlerinin (deception, IDS, WAF, SOAR, tehdit istihbaratı) küçük ama gerçekten çalışan bir versiyonu olarak tasarlanmıştır. Temel ilke: panelde görünen her alarmın ve her otomatik kararın nedeni açıkça görülebilir — süs animasyonu değil, gerçek veriye dayanır.

Genel yetenekleri:

- Sahte servislerle saldırgan tespiti ve oyalanması (deception)
- Web saldırılarını engelleyen WAF katmanı
- Port tarama, brute-force, çoklu-servis ve tekrar tespiti — açıklanabilir alarm
- Saldırı tersine mühendisliği ve MITRE ATT&CK eşlemesi
- SOAR ile otonom müdahale (geri alınabilir eylem otomatik, yıkıcı eylem insan onayına)
- Hareketli hedef savunması (MTD) ve çok katmanlı derin savunma
- STIX 2.1 / SIEM uyumlu çıktı ve kurcalama-kanıtı denetim zinciri

2. Değerlendirme Tatbikatı

Bu bir kırmızı/mavi takım tatbikatıdır. Savunmacı (mavi takım) sistemi izole bir lab ağında çalıştırır ve komuta merkezinden izler. Siz kırmızı takımsınız (saldırgan): kendi makinenizden, size verilen IP adresine yetkili güvenlik testi uygularsınız. Sistemin her katmanı gerçek veriyle çalışır; sahte veri yoktur.

3. Göreviniz — Sessiz Sızma

Bu sistemde korunan 10 haneli gizli bir parola vardır. Hedefiniz, bu parolanın düz metnini verilen IP üzerinden ele geçirmek — ve bunu mümkün olduğunca az iz bırakarak (az alarm tetikleyerek) yapmaktır.

Bu sistem bir tespit ızgarasıdır: her tarama, her deneme, her şüpheli erişim kaydedilir ve savunmacı tarafından canlı izlenir. Parolanın nerede olduğunu ve nasıl korunduğunu keşfetmek görevin bir parçasıdır. Başarı ölçütü yalnızca “parolayı aldın mı” değil; ne kadar sessiz ilerleyebildiğiniz de değerlendirilir.

4. Katılım Kuralları (Rules of Engagement)

- Kapsam yalnızca size verilen IP/hedeftir; başka hiçbir sisteme yönelmeyin.
- Test izole lab ağında yapılır; dışarıya (internet) veya üçüncü taraflara çıkış yoktur.
- Hizmet dışı bırakma (DoS) ve donanıma/veriye kalıcı zarar kapsam dışıdır.
- Kendi araç ve yöntemlerinizi serbestçe kullanabilirsiniz (recon, web, brute-force, fuzzing...).
- Test yetkili ve zaman sınırlıdır; başlangıç ve bitiş savunmacıyla birlikte belirlenir.

5. Değerlendirme Ölçütleri

Ölçüt	Ne ölçülür
İlk alarma kadar süre	Ne kadar sessiz ilerlendiği
Toplam alarm sayısı	Bırakılan iz miktarı
Ulaşılan en derin nokta	Hedefe ne kadar yaklaşıldığı
Parolanın düz metni	Elde edildi mi

Not: Amaç saldırganı “durdurmak” değil; her hamlesini görmek, açıklamak ve yanıtlamaktır. Mükemmel sonuç (sıfır alarmla parola) tasarım gereği son derece zordur.

6. Teslim

Tatbikat sonunda, denediğiniz yöntemleri, kullandığınız araçları ve ulaştığınız sonucu kısaca belgelemeniz beklenir. Ulaşamadığınız noktalar da değerlidir: “şunu denedim, şu katmanda durduruldum” bir başarısızlık değil, ölçümün kendisidir.